06 — Data processing agreement

Français (version de référence) : ../fr/06-accord-traitement-donnees.md

> **TEMPLATE — TO VALIDATE.** Annex B of the SaaS terms of service (template 02).

Header	
Jurisdiction	DRC — Digital Code, Book III (controller, processor, security, transfers)
Assumptions	H-03 (Nhill processes businesses' data on their behalf), H-04 (hosting), H-05 (authority), H-14 (retention), H-15 (breach)
Sources	S01, S07, S16 — see 00-legal-research.md § 7
Clauses to validate	V-05, V-06, V-07
Version	[NUMBER] of [DATE]

1. Parties and roles

The **Customer** (the business) is the controller of the data it records in Nhill. The **Publisher** ([COMPANY NAME]) acts as processor: it processes this data only to provide the Service and on the Customer's documented instructions, which are the contract, this agreement and the settings made in the application.

2. Description of the processing

Item	Content
Subject	business management and point of sale: sales, purchases, stock, payments, reports, team
Data subjects	the Customer's customers and suppliers, its employees and users
Data	identity and contact details, third parties' tax identifiers, purchase and payment history, users' sign-in data and activity log
Sensitive data	**none expected**; the Customer undertakes not to record any in free-text fields
Operations	recording, storage, consultation, computation, export, deletion
Duration	contract term, then reversibility (article 8 of template 02)
Location	[COUNTRY / HOSTING REGION]

3. Publisher's obligations

1. Process the data only on the Customer's instructions; inform it if an instruction seems unlawful.
2. Ensure confidentiality: authorised staff, bound by confidentiality, access limited to support and operations needs.
3. Implement the security measures of article 6.
4. Not use another processor without informing the Customer beforehand (article 5).
5. Help the Customer answer data-subject requests (exports, rectification by the Customer itself in the application).

6. Notify the Customer of any data breach affecting it **without undue delay and at the latest [24] hours** after becoming aware of it, with the information available (nature, categories and approximate volume, likely consequences, measures taken), so that the Customer can notify the authority within the legal deadline **[TO VALIDATE: V-06]**. Procedure: template 14.
7. Delete or return the data at the end of the contract (article 8 of template 02) and confirm deletion in writing on request.
8. Make available the information needed to demonstrate compliance with this agreement; allow an audit [once a year, at the Customer's cost, with 30 days' notice, by an auditor bound by confidentiality].

4. Customer's obligations

The Customer has a legal basis for each processing, informs the data subjects (including its employees: template 17), completes the formalities that fall to it with the data-protection authority, assigns access rights in the application and removes those of people who leave.

5. Sub-processors

Sub-processor	Service	Country	Safeguards
[HOST, e.g. Supabase Inc.]	PostgreSQL database	[COUNTRY / REGION]	[contract, data-protection clauses]
[API SERVER HOST]	application server	[COUNTRY]	[ ]
[PAYMENT PROVIDER]	subscription payment (not the Customer's sales)	[COUNTRY]	[ ]

The Publisher informs the Customer of any change [30] days in advance; the Customer may object on legitimate grounds and, failing agreement, terminate without penalty.

6. Security measures

- encrypted communications (TLS) between the applications and the server;
- isolation of each business's data in the database (forced row-level security, application role without bypass privilege);
- hashed passwords (Argon2id), short sessions with rotation, attempt limiting;
- role-based access control, non-modifiable audit log;
- encrypted backups, restore test;
- infrastructure secrets outside the code, protected configuration files;
- mandatory two-factor authentication for platform administrators.

These measures are reviewed at least once a year. No measure guarantees the complete absence of vulnerabilities.

7. Transfers outside the DRC

If hosting is outside the DRC, the Publisher [has obtained / is applying for] the required transfer authorisation ([REFERENCE]) and imposes on its sub-processors protection obligations at least equivalent. **[TO VALIDATE: V-05 — exact regime, split of formalities between controller and processor.]**

8. Duration

This agreement applies as long as the Publisher processes data for the Customer.

Made in [CITY], on [DATE].

For the Publisher	For the Customer
[NAME, TITLE]	[NAME, TITLE]